

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-07-01 · Source: `pom.xml` @ `61ed8c3`

Summary

Metric	Count
Total CVE findings	75
CRITICAL findings	16
HIGH findings	46
MEDIUM findings	12
LOW findings	1
Outdated dependencies	11
License violations	1
Supply-chain alerts	2

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.26.0
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379 (+ 53 more)	9.8	CRITICAL	2.22.0
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.26.0
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	8.0.33
com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	7.5	HIGH	3.21.7
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.1-jre
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.9.10
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.14.0

All CVEs (top dependencies)

CVE	Dependency	CVSS	Severity
CVE-2021-44228	log4j-core	10.0	CRITICAL
CVE-2021-45046	log4j-core	9.0	CRITICAL
CVE-2019-14379	jackson-databind	9.8	CRITICAL
CVE-2019-14540	jackson-databind	9.8	CRITICAL
CVE-2019-14892	jackson-databind	9.8	CRITICAL

CVE-2019-14893	jackson-databind	9.8	CRITICAL
CVE-2019-16335	jackson-databind	9.8	CRITICAL
CVE-2019-16942	jackson-databind	9.8	CRITICAL
CVE-2020-10672	jackson-databind	8.8	HIGH
CVE-2023-22102	mysql-connector-java	8.3	HIGH
CVE-2026-34479	log4j-core / log4j-api	7.5	HIGH
CVE-2024-7254	protobuf-java	7.5	HIGH
CVE-2023-2976	guava	7.1	HIGH
CVE-2021-44832	log4j-core	6.6	MEDIUM
CVE-2018-1000873	jackson-annotations	6.5	MEDIUM
CVE-2021-45105	log4j-core	5.9	MEDIUM
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2021-29425	commons-io	4.8	MEDIUM
CVE-2020-8908	guava	3.3	LOW

jackson-databind carries 54 total CVEs (2019–2023 deserialization/gadget-chain family); *log4j-core* carries 8 (Log4Shell + follow-ons). See `depscan-report.json` for the complete per-dependency list.

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core` (missing "er" in groupId); the coordinate does not exist on Maven Central and fails dependency resolution. **Remove immediately.**

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP, non-Central Maven repository declared in `pom.xml` (MITM / artifact-injection risk). Remove or replace with a verified HTTPS mirror.

Machine-readable source: `depscan-report.json`. Generated by the *Dependency & Supply-Chain Plugin* — Stage 1.